PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation des environnements Java sur Windows

03-560 ANSSI - Recommandations de sécurité relatives aux environnements d'exécution Java sur les postes de travail Microsoft Windows — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les outils de réduction des risques comme EMET sont peu efficaces contre les échappements de bac à sable liés aux vulnérabilités Java.
2. La mise à jour du JRE 64 bits ne protège pas contre les vulnérabilités du JRE 32 bits utilisé par Internet Explorer.
3. Il est recommandé de traiter les fichiers .jar et .jnlp avec la même vigilance que les fichiers .exe.

Synthèse des risques JRE

Notion	À retenir
Risques des JRE	Vulnérabilités fréquentes, corrections tardives, exploits **zero-day** et mises à jour non automatiques. L'**antivirus** et **EMET** sont inefficaces face aux échappements de **bac à sable**. Exemple : vulnérabilité du **27 août 2012**, bloquée par moins de la moitié des antivirus.
Versions et cohabitation	Plusieurs versions majeures peuvent cohabiter ; une appliquette peut exiger une version **ancienne et vulnérable**. Depuis le **JRE 1.6.0_10**, une boîte de dialogue demande l'autorisation de l'utilisateur, souvent sans qu'il en mesure l'impact.
Obsolescence appliquettes	Fin du support **NPAPI** par **Chrome** (septembre 2015), et à terme par **Firefox** ; **Edge** n'exécute pas d'appliquettes. **Internet Explorer 11** seul navigateur possible après **fin 2016** : anticiper le remplacement.

Phase d'inventaire Java

Notion	À retenir
Recensement applications/postes	Recenser applications (**lourdes**, **légères**, **Java Web Start**) et utilisateurs. Recenser postes et versions **JRE** via **gestion de parc** ou **scripts**. La voie **organisationnelle** est indispensable pour les applications lourdes.
Identification anomalies	Croiser les recensements pour repérer les **JRE** ou modules (**NPAPI** sous **Firefox**, **ActiveX** sous **Internet Explorer**) installés ou activés **inutilement**.

Recommandations de sécurisation Java

Notion	À retenir
Interdiction JRE	Désinstaller les **JRE inutiles** et empêcher leur réinstallation via **SRP**, **AppLocker** ou retrait des **droits d'administration locaux**.
Remplacement appliquettes	Ré-écrire les appliquettes en **applications Java Web Start autonomes** pour s'affranchir des modules complémentaires et anticiper l'obsolescence.
Configuration et déploiement	Définir une configuration via `deployment.properties` et `deployment.config` ; télédéploiement par **GPO** sur le périmètre le plus restreint.
Gestion mises à jour	Maintenir une **veille sur les alertes de sécurité** et mettre à jour les applications dans les **plus brefs délais**.

Synthèse des recommandations

Notion	À retenir
Windows 64 bits	Mettre à jour le **JRE 32 bits** en complément du **64 bits**, car **Internet Explorer** utilise par défaut la version **32 bits**.
JAR, JNLP et navigateurs	Traiter **.jar** et **.jnlp** comme des **.exe**. Utiliser **deux navigateurs distincts** (un avec modules Java pour l'intranet, l'autre sans pour Internet) si maintenables.

Pièges et confusions

- ⚠ Croire que la mise à jour du JRE 64 bits corrige les vulnérabilités du JRE 32 bits.
- ⚠ Penser que l'outil EMET est efficace contre les échappements de bac à sable Java.
- ⚠ Ré-écrire en Java Web Start une application qui agit comme un remplacement de module complémentaire avec un serveur local en écoute.
- ⚠ Croire que l'antivirus suffit contre les vulnérabilités Java : il se révèle inefficace face aux échappements de bac à sable.

Sigles et définitions

JRE	Environnement d'exécution nécessaire au fonctionnement des applications Java.
Appliquette Java	Application légère exécutée côté client via un module complémentaire du navigateur.
Java Web Start	Fonctionnalité permettant de démarrer une application Java depuis une session Web ou un fichier JNLP sans navigateur.
JNLP	Protocole de démarrage d'application Java reposant sur des fichiers décrivant les versions de JRE, l'URL et les permissions.
NPAPI	Ancienne interface de programmation sur laquelle repose le module complémentaire Java de Chrome et Firefox.

Auto-test

1. Quel navigateur était le seul possible après fin 2016 pour les appliquettes ?
2. Quels outils peuvent être utilisés pour empêcher la réinstallation des JRE ?
3. À partir de quelle version une boîte de dialogue demande-t-elle l'autorisation de l'utilisateur ?
4. Comment doit-on traiter les fichiers .jar et .jnlp ?
5. Sur quelle interface repose le module complémentaire Java de Chrome et Firefox ?

Réponses : **1.** Internet Explorer 11 · **2.** SRP, AppLocker ou retrait des droits d'administration locaux · **3.** JRE 1.6.0_10 · **4.** Comme des .exe · **5.** NPAPI

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.